

DCST1005 – Digital infrastruktur og cybersikkerhet

Mock Eksamen 2 – Løsningsforslag

Del A – Flervalg (fasit)

Spørsmål	Korrekt svar
1	a
2	b
3	a
4	b
5	a
6	a
7	b
8	b
9	b
10	b
11	b
12	a

Del B – Windows Server og on-premises administrasjon

Oppgave B1 – Active Directory og sikkerhet

a) Minste privilegium og delegering i AD

Prinsippet om minste privilegium innebærer at en bruker kun skal ha de rettighetene som er strengt nødvendige for å utføre sine arbeidsoppgaver. I en AD-kontekst betyr dette at en ny IT-administrator ikke bør legges til i gruppen `Domain Admins` med mindre det er absolutt nødvendig, da Domain Admins har ubegrenset tilgang til hele domenet.

I stedet kan rettigheter delegeres på OU-nivå ved hjelp av «**Delegate Control**»-veiviseren i Active Directory Users and Computers. Eksempler på rettigheter som kan delegeres:

- **Tilbakestille passord** for brukere i en bestemt OU
- **Opprette og slette brukerkontoer** i en bestemt OU
- **Administrere gruppedlemskap** i utvalgte grupper
- **Koble datamaskiner til domenet** (via rettigheten til å opprette datamaskinkontoobjekter)

I tillegg kan den nye administratoren legges til i innebygde grupper med begrensede rettigheter, som **Account Operators** (administrere brukere og grupper, men ikke Domain Admins) eller **Server Operators** (administrere servere, men ikke AD-objekter).

Begrunnelse: Dersom en konto med kun nødvendige rettigheter kompromitteres, begrenses skadeomfanget vesentlig sammenlignet med en kompromittert Domain Admin-konto.

b) Passordhåndtering – to tilnærminger

Alternativ 1 – Default Domain Password Policy via GPO: Pasordkrav kan konfigureres under **Computer Configuration → Windows Settings → Security Settings → Account Policies → Password Policy** i en GPO koblet til domenenivå. Her settes minimumslengde (12 tegn), kompleksitetskrav og maksimal passordaldre (90 dager).

Begrensning: Domenepolicyen gjelder for alle brukere i domenet likt. Det er ikke mulig å ha ulike passordkrav per avdeling med denne tilnærmingen.

Alternativ 2 – Fine-Grained Password Policy (FGPP): Introdusert i Windows Server 2008, FGPP muliggjør at ulike passordpolicyer knyttes direkte til spesifikke brukerkontoer eller sikkerhetsgrupper via «Password Settings Objects» (PSO). Administreres via «Active Directory Administrative Center» eller PowerShell.

Fordel i et miljø med ulike krav per avdeling: Med FGPP kan IT-drift-avdelingen for eksempel ha strengere krav (16 tegn, 60 dagers bytte) enn Salg-avdelingen (12 tegn, 90 dager), uten at dette krever separate domener. Dette er den klart mer fleksible løsningen for organisasjoner med differensierte sikkerhetskrav.

c) Stale computer accounts

En «stale computer account» er en datamaskinkonto i Active Directory som ikke lenger korresponderer med en aktiv maskin i miljøet – for eksempel en maskin som er kassert, reinstallert eller omdøpt uten at den gamle kontoen ble ryddet opp.

Sikkerhetsrisiko: En gammel datamaskinkonto kan potensielt misbrukes til å autentisere seg mot domenet dersom noen har tilgang til maskinens lagrede

legitimasjon. I tillegg skaper det unødvendig støy i AD og gjør det vanskeligere å få en korrekt oversikt over miljøet.

Opprydding:

1. Bruk `Get-ADComputer -Filter {LastLogonDate -lt (Get-Date).AddDays(-90)}` for å identifisere inaktive maskinkontoobjekter
2. Verifiser at maskinene faktisk ikke lenger er i bruk før noe gjøres
3. Deaktiver kontoene i en karanteneperiode fremfor å slette dem umiddelbart
4. Flytt deaktiverte kontoobjekter til en `Deaktivert -OU`
5. Slett permanent etter karanteneperioden

Oppgave B2 – Group Policy

a) Programvaredistribusjon via GPO

Programvaredistribusjon via GPO konfigureres under `Computer Configuration → Policies → Software Settings → Software Installation` (for distribusjon til maskiner, uavhengig av bruker) eller `User Configuration → Policies → Software Settings → Software Installation` (for distribusjon til brukere).

For å distribuere til alle maskiner i Salg-avdelingen brukes **Computer Configuration**, og GPO-en kobles til `OU=Datamaskiner > Klienter` – eventuelt med sikkerhetsfiltrering til en gruppe som kun inneholder Salg-maskinene.

Krav til pakkeformat: GPO-basert softvaredistribusjon krever at programmet er pakket som en **Windows Installer-pakke (.msi)**. EXE-installasjonsfiler støttes ikke direkte. MSI-filen må ligge tilgjengelig på et nettverksdelingsmappenivå som alle aktuelle maskiner har lesetilgang til (f.eks. `\\DC1\Software\Program.msi`).

Programmet installeres automatisk neste gang maskinene starter opp og mottar oppdatert Group Policy.

b) Feilsøking – GPO som ikke blokkerer programvareinstallasjon

Systematisk fremgangsmåte:

1. Kjør `gpresult /r` eller `gpresult /h rapport.html` på en berørt klientmaskin for å se hvilke GPO-er som faktisk er aktive for brukeren og maskinen. Kontroller at den aktuelle GPO-en vises i listen.
2. Kjør `gpupdate /force` på klientmaskinen for å sikre at nyeste versjon av GPO-en er hentet ned. Vent deretter og test på nytt.
3. **Kontroller OU-plasseringen** til brukerkontoen i Active Directory Users and Computers. Dersom brukeren ikke befinner seg i OU-en GPO-en er koblet til, vil policyen ikke gjelde.

Mulige årsaker til at GPO-en ikke virker:

- **Feil OU:** Brukerkontoen ligger i en annen OU enn der GPO-en er koblet til.
- **Security filtering:** GPO-en mangler gruppen «Authenticated Users» i sikkerhetsfiltrering, eller brukeren er ikke medlem av en gruppe som har Apply-rettigheter på GPO-en.
- **Block Inheritance:** En OU lenger ned i hierarkiet har Block Inheritance aktivert, som hindrer GPO-en fra å arves ned.
- **«Enforced» overstyrer ikke:** Dersom en annen GPO lenger ned i hierarkiet eksplisitt tillater programinstallasjon, kan den overstyre blokkeringspolicyen.
- **GPO ikke koblet:** GPO-en er opprettet men ikke koblet (linked) til riktig OU – den eksisterer kun i Group Policy Objects-kontaineren uten effekt.

c) WMI-filtre på GPO-er

Et WMI-filter er en betingelse knyttet til en GPO som bestemmer om policyen skal gjelde for en bestemt maskin basert på maskinegenskaper som kan spørres via Windows Management Instrumentation (WMI). Dersom WMI-filteret evalueres til `false` for en maskin, vil GPO-en ikke anvendes på den maskinen selv om den befinner seg i riktig OU.

Eksempel på nyttig bruk: En organisasjon har en blanding av Windows 10- og Windows 11-maskiner i samme OU og ønsker å konfigurere en innstilling som kun finnes i Windows 11. I stedet for å opprette separate OU-er for de to versjonene kan man knytte et WMI-filter til GPO-en med betingelsen:

```
SELECT * FROM Win32_OperatingSystem WHERE Version LIKE "10.0.22%"
```

Dette sikrer at GPO-en kun gjelder Windows 11-maskiner (som har versjonsnummer 10.0.22000 eller høyere), uavhengig av hvilken OU maskinene befinner seg i. Dette er spesielt nyttig når det er upraktisk eller unødvendig å omstrukturere OU-hierarkiet kun for å skille maskiner basert på én egenskap.

Del C – Azure og offentlig sky

Oppgave C1 – Hybrid sky og nettverksdesign

a) Point-to-Site VPN vs. Site-to-Site VPN

En **Point-to-Site (P2S) VPN** gir enkeltbrukere (klienter) mulighet til å koble seg til et Azure VNet via en kryptert tunnel fra sin egen enhet. Tilkoblingen initieres fra klienten og krever ikke noe dedikert VPN-utstyr på brukerens side.

En **Site-to-Site (S2S) VPN** kobler et helt on-premises nettverk til Azure via en dedikert VPN-gateway og en lokal nettverksgateway. Alle maskiner på det lokale nettverket kan nå Azure-ressurser uten individuelle klientkonfigurasjoner.

Scenario der P2S er mer hensiktsmessig: En organisasjon har ansatte som jobber hjemmefra og trenger tilgang til ressurser i Azure VNet-et. Det finnes

ingen sentralisert on-premises infrastruktur å koble til, og det er upraktisk å installere og vedlikeholde VPN-utstyr hos hver enkelt ansatt. Med P2S kan hver ansatt installere en VPN-klient på sin laptop og koble seg direkte til Azure, eventuelt med Entra ID-autentisering for ekstra sikkerhet.

b) Azure File Sync

Azure File Sync er tjenesten som passer til dette formålet. Den synkroniserer innhold mellom en on-premises Windows Server-filserver og en Azure Files-filshare i skyen.

På overordnet nivå fungerer det slik:

1. En **Storage Sync Service** opprettes i Azure
 2. En **Azure Files filshare** opprettes som skyendepunkt
 3. **Azure File Sync-agenten** installeres på den on-premises filserveren
 4. Serveren registreres som et serverendepunkt og synkroniseringen starter
- Filer er deretter tilgjengelige både lokalt og via Azure Files, og endringer synkroniseres automatisk i begge retninger.

Viktig begrensning: Azure File Sync støtter ikke alle filsystemfunksjoner. Spesielt er **symbolske lenker** og **NTFS-tillatelser** håndtert med begrensninger – NTFS ACL-er synkroniseres, men ikke all funksjonalitet er garantert bevart ved tilgang via Azure Files direkte. I tillegg har Azure File Sync begrensninger på antall serverendepunkter og volum av data per synkroniseringsgruppe, noe som bør hensyntas ved planlegging av større implementasjoner.

c) Privat vs. offentlig IP-adresse for virtuelle maskiner

En **privat IP-adresse** tildeles en VM fra adresserommet til subnettet den befinner seg i, og er kun nåbar innenfor det Azure VNet-et (og tilkoblede nettverk). En **offentlig IP-adresse** er en internettruterbar adresse som gjør VM-en direkte nåbar fra internett.

Hvorfor unngå offentlige IP-adresser direkte på produksjons-VM-er:

En VM med offentlig IP-adresse er eksponert direkte mot internett og vil umiddelbart bli utsatt for automatiserte skanninger, brute force-forsøk mot SSH/RDP og utnyttelsesforsøk mot kjente sårbarheter. Dette er en vesentlig angrepsflate selv med NSG-regler, fordi:

- Feilkonfigurerte NSG-regler kan ved en feil eksponere tjenester
- Zero-day-sårbarheter kan utnyttes før NSG-en oppdateres
- Logger og trusseldeteksjon er vanskeligere å sentralisere

Beste praksis er å bruke **Azure Bastion** for administrasjonstilgang (RDP/SSH via nettleser uten offentlig IP), eller å rute administrasjonstrafikk via en VPN-tilkobling til et dedikert administrasjonssubnett. Applikasjonstilgang kan håndteres via Azure Load Balancer eller Application Gateway, som eksponerer ett kontrollert inngangspunkt fremfor individuelle VM-er.

Oppgave C2 – Sikkerhet og tilgangsstyring

a) Microsoft Defender for Cloud

Microsoft Defender for Cloud (tidligere Azure Security Center) er en administrert tjeneste som kontinuerlig vurderer sikkerhetsstatusen til Azure-ressurser, identifiserer sårbarheter og gir anbefalinger for forbedring. Den gir en «Secure Score» som indikerer det overordnede sikkerhetsnivået.

To konkrete eksempler på sikkerhetsproblemer den kan identifisere:

1. Virtuelle maskiner med offentlig RDP/SSH-port åpen mot internett:

Defender for Cloud vil flagge dette som en høyrisikokonfigurasjon og anbefale å bruke Azure Bastion eller JIT (Just-in-Time) VM Access i stedet.

2. Manglende diskkryptering: Dersom en VM ikke har Azure Disk Encryption aktivert, vil dette rapporteres som et avvik fra sikkerhetsbenchmarks, med en anbefaling om å aktivere kryptering.

b) Managed Identity og Key Vault

Mekanismen som muliggjør at en VM kan lese fra Azure Key Vault uten lagret legitimasjon er **Managed Identity** (administrert identitet). Azure tildeler da en automatisk administrert identitet til VM-en, som brukes til å autentisere seg mot Azure-tjenester uten at noen hemmeligheter trenger å lagres i koden eller på maskinen.

Oppsett på overordnet nivå:

1. **Aktiver System-assigned Managed Identity** på den virtuelle maskinen under VM-innstillingene i Azure Portal
2. **Gå til Azure Key Vault** og velg «Access policies» eller bruk RBAC-modellen
3. **Tildel VM-ens identitet rollen Key Vault Secrets User** (med RBAC) eller gi den **Get** -rettighet på secrets (med Access Policy)
4. I koden på VM-en brukes Azure SDK eller REST API til å hente tokens automatisk fra den lokale IMDS-endeppunktet (`169.254.169.254`), som Azure håndterer internt

Resultatet er at VM-en kan autentisere seg mot Key Vault og lese hemmeligheter uten at noen legitimasjon er synlig eller lagret noe sted.

c) Network segmentation i Azure

Network segmentation betyr å dele opp et nettverksmiljø i mindre, isolerte segmenter slik at trafikk mellom segmentene kan kontrolleres og begrenses. I Azure realiseres dette primært gjennom subnett med tilknyttede NSG-er.

Hvorfor segmentere et produksjonsmiljø:

Dersom alle ressurser – webservere, applikasjonsservere og databaser – befinner seg i ett stort subnett, kan en angriper som kompromitterer én ressurs

bevege seg fritt til alle andre ressurser i subnettets uten hindring. Dette kalles lateral movement.

Med segmentering deles miljøet typisk i tre lag:

- **Frontend-subnett:** Webservere som er eksponert mot brukere
- **Applikasjonssubnett:** Applikasjonslogikk som kun er nåbar fra frontend-subnettets
- **Databasesubnett:** Databaser som kun er nåbar fra applikasjonssubnettets

NSG-er mellom hvert lag sørger for at trafikk kun kan flyte i tillatt retning og på tillatte porter. Selv om en webserver kompromitteres, kan angriperen ikke nå databasen direkte – trafikken stoppes av NSG-en ved applikasjonssubnettets grense.

Del D – PowerShell og automatisering

Oppgave D1a – Pseudokode

```
# Definer variabler
$grupper = @("GG-Økonomi", "GG-Salg", "GG-IT-drift")
$loggsti = "C:\Scripts\grupperrapport.txt"

# Funksjon for logging med tidsstempel
function Skriv-Logg {
    param($Melding)
    $tidsstempel = Get-Date -Format "yyyy-MM-dd HH:mm:ss"
    "$tidsstempel - $Melding" | Add-Content -Path $loggsti
}

# Tøm/opprett rapportfilen
Clear-Content -Path $loggsti -ErrorAction SilentlyContinue

Skriv-Logg "--- Grupperrapport startet ---"

# Iterer over hver gruppe
foreach ($gruppenavn in $grupper) {

    try {
        # Hent gruppelemmer fra AD
        $medlemmer = Get-ADGroupMember -Identity $gruppenavn -ErrorA

        # Skriv gruppeoverskrift til rapport
        Add-Content -Path $loggsti -Value ""
        Add-Content -Path $loggsti -Value "=== $gruppenavn ==="

        if ($medlemmer.Count -eq 0) {
            # Gruppen finnes men er tom
            Add-Content -Path $loggsti -Value "(Ingen medlemmer)"
            Skriv-Logg "INFO: $gruppenavn er tom"
        }
    }
}
```

```

    }
    else {
        # Skriv hvert medlem til rapporten
        foreach ($medlem in $medlemmer) {
            Add-Content -Path $loggSti -Value $medlem.SamAccount
        }
        Skriv-Logg "SUKSESS: $gruppenavn - $($medlemmer.Count) m
    }
}
catch {
    Add-Content -Path $loggSti -Value ""
    Add-Content -Path $loggSti -Value "=== $gruppenavn ==="
    Add-Content -Path $loggSti -Value "(FEIL: Gruppen ble ikke f
    Skriv-Logg "FEIL: Kunne ikke hente medlemmer for $gruppenavn
}

Skriv-Logg "---- Grupperrapport fullført ----"

```

Oppgave D1b – Begrunnelser

Valg 1 – Try-Catch rundt Get-ADGroupMember

Dersom en gruppe ikke eksisterer i AD – for eksempel fordi den er slettet eller har fått et nytt navn – vil `Get-ADGroupMember` kaste en feil og stoppe scriptet uten `Try-Catch`. Med feilhåndtering fanges dette opp, en beskrivende melding skrives til rapporten og loggen, og scriptet fortsetter med neste gruppe. I et produksjonsmiljø der rapporten kjøres automatisk og kanskje ikke overvåkes direkte, er det avgjørende at scriptet alltid fullfører og produserer en rapport – ikke stopper halvveis.

Valg 2 – Eksplisitt håndtering av tom gruppe med if -blokk

En gruppe kan eksistere i AD uten å ha noen medlemmer. Uten en sjekk på `$medlemmer.Count -eq 0` vil rapporten bare inneholde en gruppeoverskrift uten noe under – noe som kan tolkes som en feil i rapporten fremfor at gruppen faktisk er tom. Ved å skrive `(Ingen medlemmer)` eksplisitt er rapporten tydelig og selvforklarende for den som leser den.

Valg 3 – Separasjon mellom rapportinnhold og logg

Scriptet skriver to typer output: selve rapporten (gruppemedlemmer i lesbart format) og en driftslogg (tidsstemplede hendelser om hva som skjedde under kjøringen). Ved å holde disse adskilt er rapporten ren og lett å lese for mottakeren, mens loggen gir IT-avdelingen sporbarhet og feilsøkingmuligheter. Dersom alt ble skrevet til samme fil ville rapporten bli uleselig for en ikke-teknisk mottaker.